장애 대응·재발방지와 취약점 제보 규정

제1장 총칙과 장애 등급

제1조(목적과 적용 범위)
① 이 규정은 회사가 운영하는 유료 디지털 서비스(구독, 인앱결제, 디지털 콘텐츠, 게임), 회원 계정, 클라우드·데이터센터, 개발자 API에서 생기는 장애의 등급 판정, 대응, 공지, 재발방지와 외부 연구자의 취약점 제보, API 키·호출 한도 관리 기준을 정하는 것을 목적으로 한다.
② 이 규정은 회사와 계열사의 서비스 운영 조직, 온콜 담당자, 인프라·데이터센터 조직에 적용한다.
③ 회사 클라우드 상품을 쓰는 고객에게는 제3장의 서비스 수준 협약(SLA) 기준을, 개발자 API를 쓰는 개발자·파트너에게는 제6장의 기준을 적용한다.

제2조(장애 등급 체계)
① 장애는 고객 영향의 크기에 따라 SEV-1부터 SEV-5까지 5단계로 나누고, 숫자가 작을수록 심각한 장애로 본다.
② SEV-1은 다수 또는 전체 고객 대상 서비스 중단, SLA 위반, 기밀 침해, 고객 데이터 손실·노출이 있는 장애이고, SEV-2는 일부 고객 대상 서비스 중단이나 핵심 기능의 심각한 저하가 있는 장애다.
③ SEV-3는 우회책이 있는 불편이고, SEV-5는 외관상 버그다. SEV-2 이상은 모두 메이저 장애로 다룬다.
④ 고객용 서비스 상태 페이지에는 상품별 상태를 정상·일부장애·심각장애 3가지로 표시한다.
⑤ 등급별 판정 기준과 대응 수준은 별표 1과 같다.

제3조(등급 판정 원칙)
① 두 등급 사이에서 판단이 애매하면 높은 등급으로 보고 대응을 시작한다.
② 장애가 진행되는 동안에는 등급을 두고 논쟁하지 않고, 등급의 적정성은 사후분석에서 다시 따진다.
③ 경보 없이 외부에서 문제가 제보되면 일단 SEV-3 또는 SEV-4 등급으로 장애를 선언한 뒤 조사한다.
④ 다만 SEV-3 이하라도 장애 지휘자가 필요하다고 판단하면 메이저 장애 대응 절차를 적용할 수 있다.

제4조(장애 선언 기준)
① 다음 중 하나에 해당하면 장애를 선언한다.
   1. 문제 해결에 두 번째 팀이 참여해야 하는 경우
   2. 고객에게 장애가 보이는 경우
   3. 1시간 동안 집중 분석해도 해결되지 않은 경우
② 장애는 상황이 커진 뒤 수 시간 지나 선언하기보다 일찍 선언하는 편이 낫다고 보고, 평소 작은 문제에도 같은 절차를 써서 실제 장애에서 절차가 몸에 배도록 한다.
③ 다만 장애 선언 절차는 사전에 문서로 정해 두되, 그 내용은 실제 대응 참여자의 의견을 받아 만든다.

제2장 장애 대응 체계와 공지

제5조(온콜 호출과 응답 시간)
① SEV-1·SEV-2 장애는 시간대와 관계없이 온콜 담당자를 즉시 호출하고, 온콜 엔지니어는 즉시 장애 화상회의에 합류한다.
② SEV-3는 서비스 팀에 고긴급으로 호출하고, SEV-4는 저긴급으로 호출해 업무 시간에 처리하며, SEV-5는 담당 시스템 소유자에게 티켓만 배정한다.
③ 경보를 15분 안에 확인하지 않으면 장애 관리 책임자에게 자동으로 넘어간다.

④ 다만 온콜 엔지니어는 사유를 밝히지 않고도 언제든 인프라 조직장에게 에스컬레이션할 수 있다.

제6조(지휘 역할 분담)
① 장애 대응은 전체를 지휘하는 장애 지휘자, 기술 조치를 맡는 운영 담당(테크 리드), 공지를 맡는 커뮤니케이션 담당, 계획 담당의 4개 역할로 나눈다.
② 장애 중 시스템 변경은 운영 담당만 하며, 지휘자가 위임하지 않은 역할은 지휘자가 겸한다. 지휘자는 필요하면 운영 담당을 여러 명 두거나 내부·외부 공지 담당을 나눌 수 있다.
③ 계획 담당은 버그 등록과 인수인계 준비를 맡고, 장애 중 정상 상태에서 바꾼 사항을 기록해 해결 뒤 원복할 수 있게 한다.
④ 다만 지휘자 스스로 압박감이나 과부하를 느끼면 지원을 더 요청하고, 팀원이 모든 역할을 익히도록 역할을 돌아가며 맡긴다.

제7조(지휘권 인계와 상태 문서)
① 지휘자의 최우선 책무는 여러 사람이 동시에 편집할 수 있는 장애 상태 문서를 유지하는 것이다. 상태 문서는 템플릿을 쓰고 핵심 정보를 맨 위에 두며 사후분석용으로 보존한다.
② 지휘권은 특히 업무 종료 시점에 명시적으로 넘기고, 이전 지휘자는 새 지휘자가 분명히 수락할 때까지 자리를 지키며, 인계 사실을 참여자 전원에게 알린다.

제8조(장애 처리 우선순위)
① 장애 중에는 피해 확산 차단, 서비스 복구, 근본원인 분석용 증거 보존 순으로 처리한다.
② 원인이 불분명하면 최근 변경을 되돌릴 수 있는지부터 검토하고, 최근 바뀐 애플리케이션 피처 플래그는 허가 없이 이전 상태로 되돌릴 수 있다.
③ SEV-3 장애의 원인이 최근 배포이면 롤백하고, 상위 등급으로 번질 조짐을 계속 지켜본다.
④ 다만 지휘자는 현재 접근 방식이 여전히 타당한지 수시로 다시 따져 본다.

제9조(장애 공지 형식)
① 장애 공지에는 영향 범위와 현재 상태를 적고, 외부 공지는 보통 1~2문장으로 짧게 쓴다. SEV-1에서는 내부 이해관계자 통보와 대외 공지를 함께 하고, 서버 장애가 나면 영향받는 서비스에 공지한다. 노출된 고객 데이터가 개인정보이면 장애 지휘자가 개인정보 보호 전담 부서에 즉시 알린다.
② 내부 후속 공지는 1~2문장 요약, 현재 상태 2~4개 항목, 다음 단계 2~4개 항목, 다음 공지 시각과 채널로 구성한다. 고정 주기는 없지만 매 공지에 다음 공지 시점을 밝힌다.
③ 커머스 API 장애 공지는 제목 앞에 '장애' 머리말을 붙이고 장애 시각, 영향받은 API, 응답 오류(HTTP 500·503·504 등), 고객 확인 사항(재호출, 판매가·재고 확인)을 한 건의 공지로 알린다.
④ 다만 원인을 모르면 생략하지 말고 모른다고 명시하며, 공지를 보내기 전에 다른 사람의 검토를 받도록 권한다.

제10조(정기점검 사전 공지)
① 서비스 전부 중단이나 서비스 중단이 예상되는 점검은 미리 공지한다. 점검 공지는 공지사항의 '작업' 분류에 올리고 점검 일정을 제목 괄호 안에 적으며, 다수 파트너 대상 공지는 7일 이상 게시로 갈음한다.
② 외부 공지가 필요한 C1 다운타임은 약 5~6주 전에 알리고 2주·1주·3일·1일 전에 다시 알린다. 이는 변경 작업의 목표 일정이며, 회원에게 알리는 최소 기준은 유료서비스 청약철회·환불 규정의 점검 공지 기준에 따른다.
③ 커머스 API 점검 공지에는 점검 중 호출이 실패하면 잠시 뒤 재시도하고 점검 후 상품·주문 반영 여부를 확인하라는 안내를 넣는다.
④ 다만 DDoS 공격·악성코드 유포 같은 긴급 상황이면 사전 공지 없이 서비스를 중단할 수 있다.

[별표 1] 장애 등급별 판정 기준과 대응 수준

등급 | 판정 기준 | 호출과 대응 | 비고

SEV-1 | 다수·전체 고객 서비스 중단, SLA 위반, 기밀 침해, 고객 데이터 손실·노출 | 시간대 무관 즉시 호출, 온콜 엔지니어 화상회의 즉시 합류 | 내부 통보와 대외 공지 동시, 사후분석 의무

SEV-2 | 일부 고객 서비스 중단, 핵심 기능 심각 저하 | 시간대 무관 즉시 호출, 온콜 엔지니어 화상회의 즉시 합류 | 메이저 장애, 사후분석 의무

SEV-3 | 우회책이 있는 불편 | 서비스 팀 고긴급 호출 | 원인이 최근 배포이면 롤백

SEV-4 | 경보 없는 외부 제보의 초기 선언 등급(SEV-3과 함께) | 서비스 팀 저긴급 호출, 업무 시간 처리 | 조사 뒤 등급 조정

SEV-5 | 외관상 버그 | 담당 시스템 소유자에게 티켓 배정 | 호출 없음

전 등급 | 판단이 애매하면 높은 등급 | 경보 15분 미확인 시 장애 관리 책임자에게 이관 | 장애 지휘자 판단으로 메이저 장애 절차 적용 가능

제3장 이중화·재해복구와 서비스 수준

제11조(데이터센터 이중화 원칙)

① 데이터센터, 데이터, 서비스, 플랫폼, 운영도구 전 영역을 인프라 하드웨어부터 서비스 애플리케이션까지 이중화하고, 데이터는 여러 벌로 복제한다.

② 사내 계정 인증·소스 관리·앱 배포 도구·위키·이슈 관리 도구 같은 개발자 운영도구는 데이터센터 간 이중화를 마친 뒤 삼중화하고, 클라우드·플랫폼 도구는 데이터센터 단위로 삼중화한다.

③ 모니터링 시스템은 재난 규모와 관계없이 장애 탐지가 동작하도록 다중화하고, 대용량 트래픽 서비스는 데이터센터 간 전용망으로 삼중화한다.

④ 다만 운영도구를 이중화하지 않거나 한 데이터센터 안에서만 이중화하면 전면 장애로 이어지므로, 운영도구는 다른 데이터센터와 이중화한다. 서비스 시스템은 이중화로 끝내지 않고 서비스 간 의존성과 강한 연동을 줄여 핵심 기능이 단독으로 실행되게 한다.

제12조(데이터센터 설비와 방재)

① 외부 전력 공급 경로와 데이터센터 내부 전력 시스템을 이중화하고, 전력과 공조 설비를 Tier III 수준으로 갖추며, 데이터센터는 24시간 365일 운영한다.

② 다중 통신 경로와 여러 통신 사업자 연동 가능 여부를 점검하고, 서버룸은 독립 케이지 구조로 만들며, 데이터센터 전용 건물이나 그 목적으로 개조한 건물만 쓴다.

③ 배터리실 화재에 대비해 전기 판넬별 개별 소화장치, 규정량 이상 소화가스와 다른 층 가스를 끌어쓰는 예비 체계, 가스 진화 실패 시 구역 차단 후 냉각수 충전의 3단계 진화 체계를 갖춘다.

④ 다만 소방 출동 때 데이터센터 전력 중단을 최소화하도록 지역 소방서와 합동 모의훈련을 협의한다.

제13조(재해복구와 원인 조사)

① 회사는 데이터센터에 침수·해일·강풍·지진 대비책을 갖추고, 자연재해와 인위적 사고에 대비한 비상대응계획(BCP)과 재해복구(DR) 체계를 둔다.

② 데이터센터 단위의 대규모 장애가 나면 외부 위원장이 참여한 원인조사를 하고, 과거 원인 분석·현재 재발방지책·미래 투자의 세 관점으로 재발방지 과제를 세운다.

③ 회사는 인프라 조직과 IT 엔지니어링 전담 조직을 두고 IT 엔지니어링 혁신 계획을 세워 인재를 확보한다.

④ 다만 원인조사에서는 전원이 끊길 때 모니터링·분석 도구까지 멈췄는지, 데이터센터와 운영관리 도구의 이중화가 미흡했는지, 가용 자원이 부족했는지를 반드시 살핀다.

제14조(가용률 목표와 서비스 크레딧)

① 클라우드 상품은 월간 가용률 목표를 정하고, 미달하면 월 이용요금의 일정 비율을 서비스 크레딧으로 지급한다. 상품별 기준은 별표 2와 같다.
② 클라우드 데이터베이스 상품은 고가용성(HA)을 선택한 고객에게만 월 99.95%를 적용하고, 99.0% 이상 99.95% 미만은 10%, 95% 이상 99.0% 미만은 25%, 95% 미만은 100%를 지급한다.
③ 공공 부문용 협업 서비스는 월 99.9% 이상을 목표로 하고, 구성원 중 접속 불가 비율이 5분 단위로 5%를 넘으면 장애로 보며, 99.9% 미만 구간별로 10%·25%·50%를 지급한다.
④ 다만 별도 계약이 없으면 크레딧을 가용성 문제에 대한 클라우드 상품 고객의 유일한 구제 수단으로 하며, 회원 대상 유료서비스의 장애 보상은 유료서비스 청약철회·환불 규정에 따른다.

제15조(크레딧 청구와 적용 제외)
① 크레딧은 장애가 난 달의 다음 달 말일까지 고객센터에 청구한다.
② 클라우드 데이터베이스 상품은 상품명·인스턴스 ID·장애 일시·로그를 내게 하고, 확인되면 청구 다음 달 말일까지 지급하며 100원 미만은 버린다. 공공 부문용 협업 서비스는 장애 내용·청구액·산출 근거를 서면으로 내게 하고 10원 미만은 버린다.
③ 불가항력, 고객 측 장비·과실, 사전 계획된 점검, 사고 확산을 막기 위한 회사의 중단 조치, 베타·무료 이용 기간은 SLA에서 제외한다.
④ 다만 공공 부문용 협업 서비스는 일부 기능만 중단된 경우와 화상회의 제공사의 결함도 제외한다.

[별표 2] 클라우드 상품별 서비스 크레딧 기준

구분	클라우드 데이터베이스 상품	공공 부문용 협업 서비스
적용 대상	고가용성(HA) 선택 고객	공공 부문 고객
월간 가용률 목표	99.95%	99.9% 이상
크레딧 비율	99.0% 이상 99.95% 미만 10%, 95% 이상 99.0% 미만 25%, 95% 미만 100%	99.9% 미만 구간별 10%·25%·50%
장애 판단	월간 가용률 기준	5분 단위 접속 불가 구성원 5% 초과
청구 기한	장애가 난 달의 다음 달 말일	장애가 난 달의 다음 달 말일
제출 자료	상품명·인스턴스 ID·장애 일시·로그	장애 내용·청구액·산출 근거(서면)
끝전 처리	100원 미만 버림	10원 미만 버림
추가 제외	없음	일부 기능 중단, 화상회의 제공사 결함

제4장 사후분석과 재발방지 과제

제16조(사후분석 작성 대상)
① SEV-1·SEV-2 장애는 사후분석(포스트모템)을 반드시 쓰고, 그 밖의 장애는 선택으로 둔다.
② 다음 중 하나에 해당하면 등급과 관계없이 사후분석을 쓴다.
1. 팀이 미리 정한 기준을 넘는 사용자 가시 중단·성능 저하
2. 종류를 불문한 데이터 손실
3. 롤백·트래픽 우회 같은 온콜 개입
4. 기준을 넘는 해결 시간
5. 수동 발견 같은 모니터링 실패
③ 다만 위 기준에 해당하지 않아도 이해관계자 누구나 사후분석 작성을 요청할 수 있다.

제17조(사후분석 오너와 회의 기한)
① 사후분석은 오너 1명이 끝까지 책임진다. 장애 지휘자가 대응자 중 1명을 오너로 지정해 직접 알리고, 오너는 장애 해결 중 또는 직후 사후분석 이슈를 만들어 승인까지 관리한다.

② 사후분석 회의는 SEV-1은 3일(달력일), SEV-2는 5영업일 안에 30분~1시간 일정으로 잡고, 최소 24시간 전에 문서 링크를 공유한다.
③ 회의에는 장애 지휘자, 관련 서비스 오너, 핵심 대응 엔지니어, 영향받은 시스템의 엔지니어링 매니저와 프로덕트 매니저가 참석한다.
④ 다만 고객 담당자는 SEV-1 회의에만 선택적으로 부르고, 사후분석 승인자는 서비스 그룹별로 미리 지정해 둔다.

제18조(비난 없는 사후분석)
① 사후분석은 개인이나 팀을 탓하지 않고, 모두 당시 정보로 선의로 행동했다고 전제하며, 사람 대신 시스템과 절차를 고친다.
② 사람은 이름 대신 역할로 부르고, 회의 시작 때 비난 없는 회의임을 밝히며, 영향에서 출발해 '왜'를 반복하는 5 Whys로 근본원인을 찾고 각 단계를 기록한다.
③ 초안은 시니어 엔지니어가 검토해 핵심 데이터 수집, 영향 평가, 근본원인의 깊이, 조치 계획과 우선순위, 이해관계자 공유를 확인한 뒤 팀·조직 저장소에 보관하고 넓게 공유한다.
④ 다만 최종본에는 최종 사용자를 식별할 수 있는 정보를 넣지 않는다.

제19조(재발방지 과제 이행)
① 사후분석에서 나온 조치는 모두 이슈 추적 시스템의 티켓으로 등록해 등급 태그와 날짜 태그를 붙이고 이행 기한을 관리한다. 사후분석의 '잘 안 된 점'에 적힌 항목은 모두 후속 조치한다.
② 근본원인을 고치는 우선 조치의 이행 목표는 서비스에 따라 4주 또는 8주로 두고, 근본원인이 아닌 개선은 개선 조치로 따로 추적한다.
③ 다만 사후분석의 영향 항목은 장애 지속 시간, 영향받은 계정·사용자 수, 지원 문의 건수처럼 정확한 숫자로 적고, 타임라인은 한국 시각 기준으로 기록한다.

제20조(사후 보고서 공개)
① 광범위한 고객 영향이 있었던 장애는 원인과 재발방지 조치를 대외에 공개한다.
② 클라우드 서비스에서 컨트롤 플레인 API 호출의 상당 비율 실패, 서비스 인프라·자원·API의 상당 비율 영향, 전면 정전이나 중대한 네트워크 장애 중 하나가 있으면 이슈 종료 뒤 사후 요약을 게시하고 최소 5년간 공개한다.
③ 대외 장애 보고서에는 원인, 한국 시각 기준 분 단위 타임라인, 영향 트래픽 비율, 후속 조치를 담는다.

제21조(학습과 대응 훈련)
① 지난 장애를 다시 살펴 대응 역량을 기르는 활동을 정기적으로 한다.
② 월간 뉴스레터의 '이달의 포스트모템', 사후분석 토론 모임과 읽기 모임, 과거 장애를 당시 지휘자와 함께 역할극으로 재현하는 장애 재현 훈련, 사후분석 부담에 대한 정기 설문을 운영한다.
③ 잘 쓴 사후분석은 공개적으로 칭찬하고, 경영진이 사후분석 활동에 직접 참여한다.

제5장 배포 통제와 롤백

제22조(변경 위험 등급과 승인)
① 프로덕션 변경은 위험도에 따라 C1~C4로 나누고 등급별로 승인 요건을 달리한다.
② C1은 고위험 변경으로, 계획 가능한 경우 최소 2주 전에 준비하고 작성자와 다른 팀의 인프라 조직장과 온콜 엔지니어의 승인을 받으며, 릴리스 매니저가 배포를 멈출 수 있게 알리고 온콜 엔지니어가 실행 내내 함께한다.
③ C2는 다운타임이 없는 고위험 변경으로 수석 엔지니어 이상과 온콜 엔지니어의 승인을, C3는 수동 단계가 있는 저위험 변경으로 다른 신뢰성 담당자의 검토를 받고, C4는 자동화된 저위험 변경이라 승인이

필요 없다.
④ 다만 데이터베이스 서비스 변경은 DB 신뢰성 담당자 검토를, 데이터베이스 모델 변경은 DB 담당 리드 승인을 따로 받는다.

제23조(배포 동결)
① 월간 릴리스일과 매주 금요일 18:00~월요일 09:00는 Soft 동결로 두어 C2 이상 인프라 변경과 배포 후 마이그레이션을 막고, C3·C4 변경과 마이그레이션 없는 배포는 온콜 엔지니어와 협의해 허용한다.
② 설·추석 연휴 전후(연휴 직전 영업일 18:00~연휴 직후 영업일 09:00)와 연말연시(12월 24일 18:00~1월 첫 영업일 09:00)는 Hard 동결로 두어 모든 배포·C1~C4 변경·피처 플래그 전환을 막는다.
③ 네트워크 전역 장애가 난 뒤에는 더 나은 완화·롤백 체계가 갖춰질 때까지 네트워크의 모든 변경을 동결할 수 있다.
④ 다만 Hard 동결 중에도 진행 중인 SEV-1·SEV-2 장애 대응은 온콜 엔지니어와 장애 관리 책임자가 모두 승인하면 허용하고, 그 밖의 예외는 사유와 매출 영향을 적어 인프라 담당 임원의 승인을 받는다.

제24조(점진 배포와 롤백)
① 프로덕션 변경은 문제가 생기면 즉시 되돌릴 수 있는 상태에서만 한다. 검토된 롤백 계획을 갖추고, 문제 대응 시간이 몇 시간 남도록 변경을 업무일 이른 시간에 잡으며, 오래 걸리는 C1·C2 작업에는 안전한 중단 지점을 둔다.
② 수 초 만에 전 네트워크로 퍼지는 전역 설정 시스템으로 변경을 한꺼번에 적용하지 않고, 설정 데이터에도 점진 배포·헬스 검증·빠른 롤백을 적용한다.
③ 다만 설정이 손상되면 요청을 버리지 않고 검증된 정상값으로 동작하게 한다.

제6장 취약점 제보와 API 키·호출 한도

제25조(취약점 제보 창구)
① 외부 연구자의 취약점 제보는 회사가 지정한 전용 창구로만 받는다. 회사는 외부 버그바운티 플랫폼에 개설한 회사 버그바운티 프로그램으로 제보를 받고, 개발자 API 관련 취약점은 개발자 커뮤니티로도 받는다.
② 프로그램 정책·범위에 관한 질문만 버그바운티 전용 이메일로 받고, 취약점 관련 소통은 제보 건 안에서만 한다.
③ 다만 클라우드 고객이 규제 준수 목적의 모의침투 테스트를 하려면 회사와 사전 협의를 거친다.

제26조(제보 범위와 금지 행위)
① 서비스 거부(DoS·DDoS) 공격과 사회공학 기법은 제보 대상에서 빼고, 취약점은 해결 전까지 외부에 공개하지 않는다.
② 인증 우회·무단 데이터 접근·데이터 수정·원격 코드 실행 같은 중대한 취약점을 주된 대상으로 하고, 테스트는 제보자가 버그바운티 플랫폼 등록 이메일로 직접 만든 본인 계정·스토어에서만 한다. 입증에 필요한 범위를 넘는 데이터 내려받기는 금지한다.
③ 자동 스캐닝 도구를 쓰면 IP 차단이나 당국 신고를 할 수 있고, 프로그램 문의나 사전 검증을 위해 고객센터에 연락해서는 안 된다.
④ 다만 한 사용자의 단일 요청으로 서비스 전체가 크게 멈추는 DoS는 검토하며, 이때 작게 시작해 저하가 보이면 멈추고 보고한다.

제27조(제보 응답과 포상)
① 제보를 받으면 3영업일 안에 평가 결과와 예상 해결 일정을 답한다.

② 포상은 최대 1억 원으로 하고, 분류(트리아지) 뒤 1주 안에 지급하도록 노력한다. 질문에 2주 동안 답이 없으면 제보자는 버그바운티 플랫폼에 중재를 요청할 수 있다.
③ 지침을 지킨 선의의 제보자에게는 법적 조치를 하지 않고, 미공개·미보고 취약점 제보자의 공로를 인정한다.
④ 다만 규칙을 하나라도 어기면 포상 자격을 잃고, 기능 오류는 포상 대상이 아니며, 서드파티 앱 문제는 그 앱 개발자가 1주 안에 응답하지 않을 때만 받는다.

제28조(API 키 종류와 보관)
① 모든 권한을 가진 키와 시크릿은 서버에서만 쓰고 클라이언트나 브라우저에 노출하지 않는다.
② 키는 플랫폼 키(REST API·JavaScript·네이티브 앱 키)와 어드민 키로 나누고, 어드민 키 값은 앱 오너만 보고 관리하며, 키는 종류별로 최대 5개까지 추가할 수 있다.
③ 비밀 키·액세스 토큰은 회사의 사전 승낙 없이 타인에게 제공할 수 없다. 발급받은 인증 정보의 유출 방지 책임은 개발자·파트너가 지고, 서면 동의 없는 양도·대여는 금지한다.
④ 다만 액세스 토큰 유효기간은 2시간, 리프레시 토큰은 14일로 하고, DB에 토큰을 저장하면 암호화하며 사용자 정보를 시스템 로그에 남기지 않는다.

제29조(키 유출 시 조치)
① 키가 유출되면 오너 계정으로 새 키를 발급해 서비스에 적용한 뒤 기존 키를 삭제해 무효화한다. 삭제한 키는 복구할 수 없으므로 교체를 마친 뒤 지운다.
② 복제 키는 원본 설정을 유지한 채 값만 바꾸지만 원본 키가 자동으로 비활성화되지 않으므로, 전환 뒤 원본 키를 직접 삭제한다.
③ 클라이언트 시크릿은 끄기, 재발급, 서비스 적용, 다시 켜기 순서로 바꾸며, 재발급 뒤 이전 코드로 하는 토큰 요청은 모두 실패한다.
④ 호출 허용 IP를 최대 10개까지 등록해 토큰이 새도 외부에서 쓰지 못하게 하도록 권하며, 등록하지 않은 IP의 호출은 오류 코드 -401로 막는다.
⑤ 다만 개발자·파트너는 보안 사고나 이상 징후를 알게 되면 회사에 즉시 알린다.

제30조(API 호출 한도와 초과 대응)
① API 호출 한도를 넘은 요청은 처리하지 않고 HTTP 429 오류로 돌려준다. API 종류별 한도는 별표 3과 같다.
② 플랫폼 API는 운영정책에 따라 하루 총 호출 1,000만 건, 월간 사용자 50만 명, 요청 30초를 넘으면 자동으로 제한한다.
③ 한도를 넘으면 1·2·4·8·16초 간격의 지수 백오프로 재시도하고 사용률이 80%를 넘으면 호출 속도를 줄이며, 초당 요청 수로 한도를 두는 API는 요청을 큐에 쌓아 1초 간격으로 보내도록 권한다.
④ 다만 의무를 어기면 경고, 데이터 삭제 요구, 일시정지, 이용계약 해지 순으로 제재하고, 같은 해에 이용 제한을 2회 이상 받으면 계약을 해지할 수 있다.

[별표 3] API 종류별 호출 한도

구분	플랫폼 API	커머스 API	파트너 앱 API
한도 기준	월·일 쿼터(무료 월 300만 건)	초당 요청 수(RPS), 앱·API별	10분 단위 쿼터와 버킷
대표 수치	메시지 API 일 3만 건	판매자 본인 스토어용 앱 전 API 2RPS 고정	10분 3,000회·처리 600초, 버킷 40·초당 2회
순간 초과 허용	따로 두지 않음	다음 1초 한도 당겨쓰기(최대 2배)	버킷 크기까지 흡수
초과 시 응답	HTTP 429	HTTP 429	HTTP 429
한도 확인 수단	쿼터 안내 문서	응답 헤더(남은 한도 등)	응답 헤더(사용량/용량)

부칙

제1조(시행일) 이 규정은 2026년 11월 3일부터 시행한다.

제2조(관계 법령 우선) 이 규정에 정하지 않은 사항이나 관계 법령과 다른 사항은 관계 법령에 따른다.